Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad _____ Grup _____ Tarih _____

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Arvasis'in kapıları (ipucu)
İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: konveyörde/ret mekanizmasında el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış saldırgan → internete doğrudan açık uzak bakım modülü (admin/admin servis hesabı) → Safety PLC'ye ulaşıp kapak kilidi/ışık perdesi parametresini devre dışı bırakır → kapak açıkken konveyör ve ret mekanizması çalışır → **operatörün eli/parmağı ezilir**	3	3	2	**3×3×2 = 18**	**KRİTİK**
Yakındaki kötü niyetli kişi → Wi-Fi (karton parola) veya port 80 HMI → ret mekanizmasının hız/zamanlamasını değiştirir → itici beklenmedik zamanda ve güçle çalışır → **operatörün eli çarpma/sıkışma yaşar**	2	2	3	**2×2×3 = 12**	**YÜKSEK**
Zararlı yazılımlı USB (kilitsiz port) → mühendislik/servis erişimi → Safety PLC'ye bozuk konfigürasyon yüklenir → emniyet fonksiyonu sessizce çalışmaz → **ilk bakım müdahalesinde kaza**	1	3	1	**1×3×1 = 3**	**DÜŞÜK · S=3 → ÖNE ALINIR**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**
   Senaryo 1 — saldırı yolu doğrudan internete açık olduğu için olasılık yüksek (L=3) ve zincir sonunda ciddi bir insan yaralanması (S=3) var.

2. **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**
   Evet, **Senaryo 3** (skor 3 → Düşük, ama S=3). Risk Register'da skora bakılmaksızın **"S=3 · Öncelikli"** etiketiyle ayrı bir sütunda işaretlenir, risk toplantısında en üstte gösterilir; sahibi ve kontrol önlemi (USB kilidi, imzalı konfigürasyon, yükleme sonrası safety doğrulama) atanır ve gözden geçirme tarihi verilir.

Altın kural kontrolü: Üç zincirin hiçbiri "veri çalındı" ile bitmiyor; her biri "bu, hattaki insana ne yapar?" sorusuna fiziksel sonuçla cevap veriyor.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.